

Module 1 : Introduction to Ethical Hacking

Learning Objectives

Explain Information Security concepts	Explain Hacking Concepts and Different Hacker Classes.
Explain Ethical Hacking Concepts and Scope	Explain Hacking Methodologies and Frameworks
Summarize the Techniques used in Information Security Controls.	Explain the Importance of Applicable Security Laws and Standards

1. Explain Information Security concepts

Information security is the protection of information and information systems that use , store or transmit information from Unauthorized access , alteration and destruction.

This section introduces the

1.1 Elements of information security.

1.2 Classification of attacks.

1.3 Information warfare.

1.1 Elements of information security.

● Elements of Information Security

Confidentiality	● Information is only accessible to authorized person. ● Reason: Due to improper data handling or hacking attempt. ● Controls: Data classification , Encryption and proper disposal of equipments (DVDs ,USB etc).
Integrity	● Accuracy of data. No changes in data. ● Measures: 1. Checksum. 2. Access control (only authorize person can change data).
Availability	● System responsible for delivering , storing and processing information remain available for authorize person when required. ● Measures : 1. Disk arrays for redundant systems and clustered machines. 2. Antivirus software to combat malware. 3. DDoS prevention systems.
Authenticity	● Characteristics of Communication or document or any data to ensure the quality of being genuine. Ensures the identity and origin of data or entities. ● Ensure User is genuine.

	● Measures: 1. Smart card. 2. Biometrics.
Non-Repudiation	● Non-repudiation is a way to guarantee that the sender of a message cannot later deny having sent the message and that the recipient cannot deny having received the message. ● Measures : Digital Signatures.

❖ Information Security Attacks: Motives, Goals, and Objectives:

Attack= motive (goal) + Method (TPP) + Vulnerability

❖ Tactics, Techniques, and Procedures (TTPs):

Tactics	Techniques	Techniques
Strategy Adopted by an attack to perform attack from start to end.	Technical methods to achieve intermediate results during attack.	Systematic approach adopted by threat actor to launch an attack.
Goals.	How they gonna do.	Tools used.
Understanding the tactics helps to predict and detect evolving threats in the early stages.	Understanding the techniques used by attackers helps to identify vulnerabilities and implement defensive measures in advance.	Analyzing the procedures used by the attackers helps to identify what the attacker is looking for within the target organization's infrastructure.

❖ Vulnerability:

Weakness in an asset that can be exploit by an attacker.

❖ Common Reasons for the Existence of Vulnerabilities:

1. Hardware or software misconfiguration:

- Misconfiguration leads to security loopholes.
- Hardware misconfiguration allow attacker to access network and system.

- Software misconfiguration allow attacker to access application and data.

2. Insecure or poor design of network and application:

- If Firewalls , IDS and VPN are not implemented securely they can expose network to various threats.

3. Inherent technology weaknesses:

- Using of old web browsers can lead to various attacks.
- If the system is not up to date , you can loss data due to small torjan horse attack.

4. User carelessness:

- Sharing secret information or clicking on suspicious link can leads to data loss.

5. Intentional end user act:

- Ex empolyee who have access to sensitive data can misuse data.

Technological Vulnerabilities	Description
TCP / IP Protocol	● HTTP. ● FTP. ● ICMP ● SMTP ● SNMP are insecure
OS	● Inherently insecure ● Not up-to-date
Network Devices	● Not password protected. ● No authentication use. ● Insecure routing protocols. ● Firewall vulnerabilities.

1.2 Classification of Attacks

1. Passive Attack:

- Passive attacks involve monitoring and intercepting network traffic on target network.
- Do not temper the data.
- Attacker perform reconnaissance on network activities using sniffers.

For example:

- Attacker can information such as unencrypted data in transit, clear text password or any other information useful in passive attack.
 - **Foot-printing.**
 - **Sniffing and eavesdropping.**
 - **Network traffic analysis.**
 - **Decryption of weakly encrypted traffic.**

2. Active Attack:

- In active attack attacker tamper the data in transit or disrupt communication or services between system to bypass or break into secure system.
- Attacker launch attack on target network or system by sending the active traffic that can be detected.
- Attacker penetrate or infect network and gain remote access to system to infect internal network.

Examples:

1. Denial-of-service (DoS) attack.
2. Bypassing protection mechanisms.
3. Malware attacks (such as viruses, worms, ransomware).
4. Modification of information.
5. Spoofing attacks.
6. Replay attacks.
7. Password-based attacks.
8. Session hijacking.
9. Man-in-the-Middle attack.

10. DNS and ARP poisoning.
11. Compromised-key attack.
12. Firewall and IDS attack.
13. Profiling.
14. Arbitrary code execution.
15. Privilege escalation.
16. Backdoor access.
17. Cryptography attacks.
18. SQL injection.
19. XSS attacks.
20. Directory traversal attacks.
21. Exploitation of application and OS software.

3. Close-in Attack:

- A close-in attack occurs when an attacker is physically near the target system, network, or facility.

Examples of close-in attacks:

- **Social engineering** (Eavesdropping, shoulder surfing, dumpster diving, and other methods).

4. Insider Attack:

- Performed by trusted person who have privileged access to critical assets.

5. Distribution Attack:

- Occur when attacker temper with hardware or software prior to installation.

Examples of distribution attack:

- Backdoors created by software or hardware vendors at the time of manufacture.

1.3 Information warfare:

The term information warfare refers to the use of information and communication technologies (ICT) to gain competitive advantages over an opponent.

- **Defensive Information Warfare:** Involves all strategies and actions to defend against attacks on ICT assets.
 - **Offensive Information Warfare:** Involves attacks against the ICT assets of an opponent.
-

Objective 2 :

Explain Hacking Concepts and Different Hacker Classes.

This Section introduce:

2.1 What is hacking.

2.2 Who is hacker.

2.3 Hacker Classes

2.1 Hacking

❖ Hacking refers to exploit system vulnerabilities or compromise security controls to gain unauthorized access to system resources.

❖ **Network hacking techniques include:**

1. Creating viruses and worms.
2. Performing denial-of-service(DoS) attacks.

3. Unauthorized remote access connections using trojans or backdoors, creating botnets, packet sniffing, phishing, and password cracking.
-

2.2 Who is hacker

❖ A **hacker** is a person who breaks into a system or network without authorization to destroy, steal sensitive data, or perform malicious attacks.

Hacker Classes	Background
Script kiddies	Inexperienced, often young individuals using pre-made scripts or tools without understanding them.
White Hat Hackers	Professionals in cybersecurity
Black Hat Hackers	Individuals with extraordinary computing skills
Gray Hat Hackers	Skilled hackers operating between ethical and unethical lines
Hacktivists	Politically or socially motivated individuals or groups
State-Sponsored Hackers	Highly trained professionals working for government agencies
Cyber Terrorists	Extremists using cyber attacks to promote political or religious beliefs
Corporate Spies (Industrial Spies)	Individuals hired by companies to gather intelligence on competitors
Blue Hat Hackers	Security professionals hired temporarily to test systems before product release
Red Hat Hackers	Vigilantes targeting black hat hackers using aggressive methods

Green Hat Hackers	Newcomers eager to learn hacking skills, often participating in online forums and Communities.
--------------------------	--

Objective 3 : Explain Ethical Hacking Concepts and Scope

This section provides an overview of :

- 3.1 Ethical hacking.**
 - 3.2 Why ethical hacking is necessary.**
 - 3.3 The scope and limitations of ethical hacking.**
 - 3.4 The skills of an ethical hacker.**
-

3.1 Ethical Hacking

What is Ethical Hacking?

Ethical hacking involves the use of hacking tools, tricks, and techniques to identify vulnerabilities and ensure system security

Ethical hackers perform security assessments for an organization with the permission of concerned authorities.

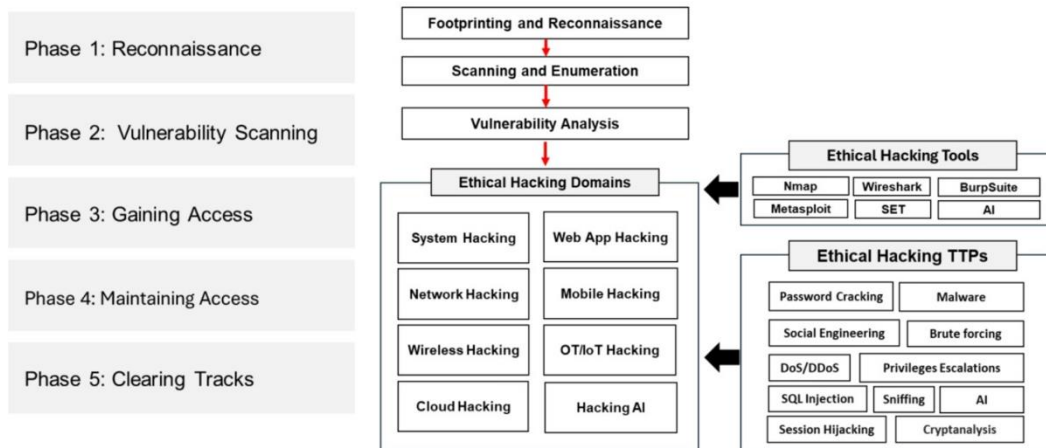
3.2 Why ethical hacking is necessary.

- To prevent hackers from gaining access to the organization's information systems.
- To uncover vulnerabilities in systems and explore their potential as a risk.
- To analyze and strengthen an organization's security posture, including policies, network protection infrastructure, and end-user practices.

Objective 4 :

Explain Hacking Methodologies and Frameworks

EC CEH Hacking Method:



Phase 1 : Reconnaissance:

- Attacker gain information as much as he can about target prior to attack.
- Attacker create profile of target organization and gain information such as ip address range ,namespace and employees.

For example:

- Organization website may provide employee **biographies** or a **personnel directory**, which the hacker can use for social engineering.
- Conducting a **Whois** query on the web can provide information about the **networks and domain names associated** with a specific organization.
- The footprinting target range may include the target organization's **clients, employees, operations, network, and systems**.

Reconnaissance divide into two Techniques:

Passive Reconnaissance:

- When an attacker is using passive reconnaissance techniques, they do not interact with the target directly. Instead, the attacker relies on publicly available information, news releases, or other no-contact methods.

Active Reconnaissance:

- Active reconnaissance techniques, on the other hand, involve **direct interactions** with the target system by using **tools** to detect
 - i. **Open ports.**
 - ii. **Accessible hosts.**
 - iii. **Router locations.**
 - iv. **Network mapping.**
 - v. **Details of operating systems, and applications.**

Scanning:

Scanning is used to identify

- I. **Active hosts.**
- II. **Open ports.**
- III. **Unnecessary services enabled on particular hosts.**

In this phase, the attacker uses the details gathered during **reconnaissance** to scan the network for specific information. **There is a slight difference in that scanning involves more in-depth probing by the attacker. Often, the reconnaissance and scanning phases overlap, and it is not always possible to separate them.**

Enumeration:

Enumeration involves making **active connections to a target system or subjecting it to direct queries**. It is a method of intrusive probing through which attackers gather information such as

- I. **Network user lists.**
- II. **Routing tables.**
- III. **Security flaws.**
- IV. **shared users, groups, applications, and banners.**

Phase 2 : Vulnerability Scanning:

Vulnerability assessment is the **examination** of the ability of a system or application, including its **current security procedures and controls**, to withstand assault.

Attackers perform vulnerability analysis to identify security loopholes in the target organization's network, communication infrastructure, and end systems.

Phase 3 : Gaining Access:

The previous phases help attackers identify **security loopholes and vulnerabilities** the target organizational IT assets.

Attackers use this information, along with **techniques such as password cracking and the exploitation of vulnerabilities** including **buffer overflows**, to gain access to the target organizational system.

Gaining access refers to the point at which the attacker obtains access to the operating system (OS) or applications on a computer or network.

A hacker's chances of gaining access to a target system depend on several factors, such as

- **Architecture and configuration of the target system.**
- **The perpetrator's skill level.**
- **The initial level of access obtained.**

Once an attacker gains access to the target system, they attempt to **escalate privileges** to obtain complete control. In this process, they also compromise intermediate systems connected to it.

Escalating Privileges:

After gaining access to a system using a **low-privilege user account**, the attacker may attempt to increase their privileges to the **administrator level** to perform protected system operations so that they can proceed to the next level of the system hacking phase, which is the execution of applications. The attacker exploits known system vulnerabilities to escalate user privileges.

Phase 4 : Maintaining Access:

Once an attacker gains **access** to the **target system** with **admin- or root-level privileges** (thus owning the system), they can use both the system and its resources at will.

The attacker can either use the **system** as a **launchpad** to **scan** and **exploit** other **systems** or **maintain a low profile and continue exploitation**.

Attackers can **upload, download, or manipulate data, applications, and configurations** on the owned system and also use **malicious software** to transfer **usernames, passwords, and any other information stored in the system**.

They can maintain control over the system for a long time by **closing vulnerabilities** to **prevent** other **hackers** from **exploiting** them. . Attackers use compromised systems

to launch further attacks.

Phase 5 : Clearing track:

To remain undetected, it is important for attackers to erase all the evidence of security compromise from the system. To achieve this, they might modify or delete logs in the system using certain **log-wiping utilities**, thus removing all evidence of their presence.

Cyber Kill Chain Methodology

The Cyber Kill Chain is a framework used by cybersecurity professionals to understand how a cyberattack progresses from beginning to end.

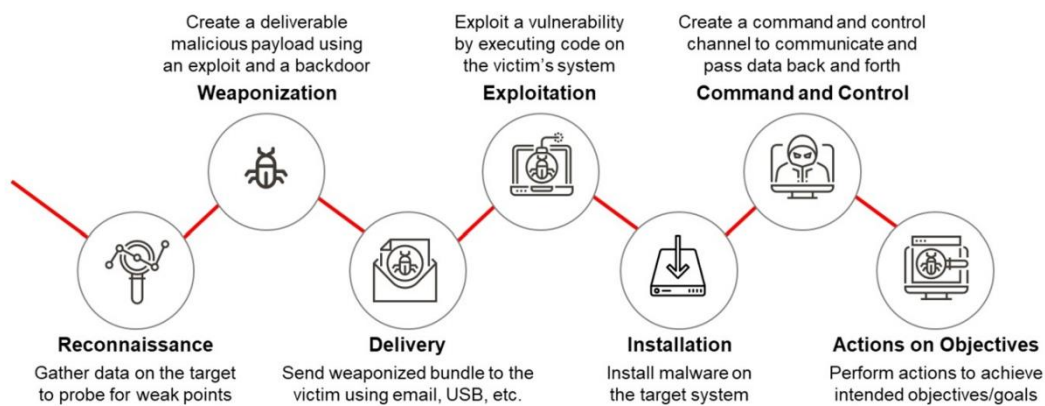
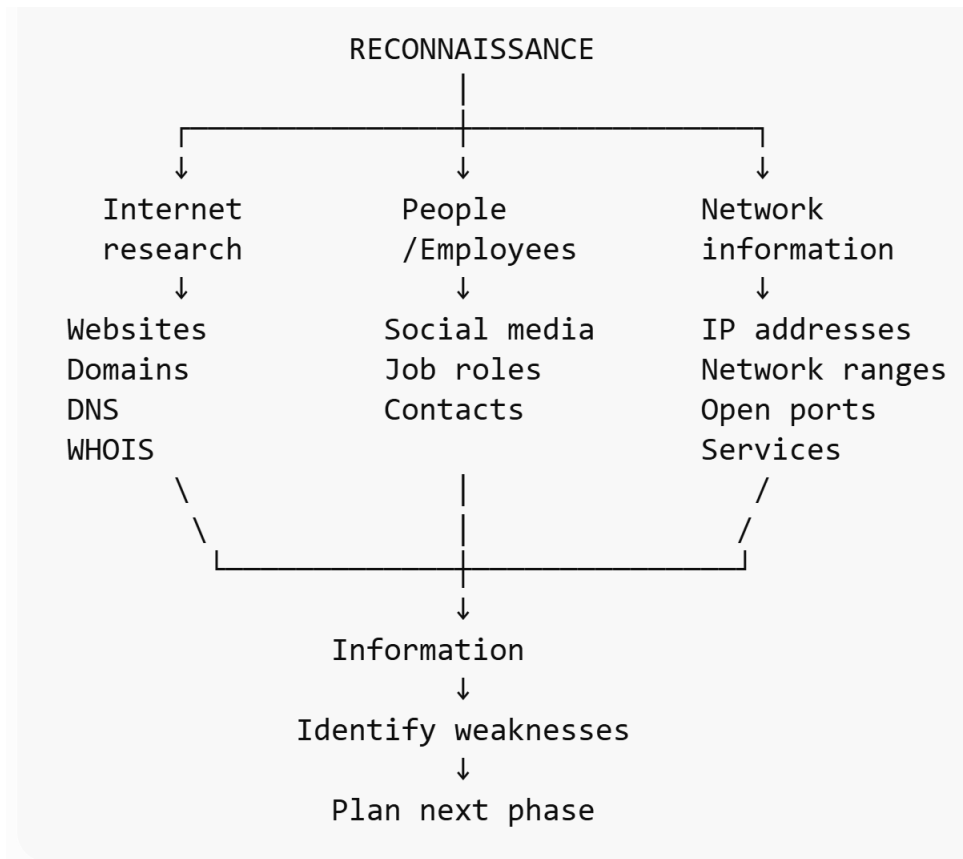
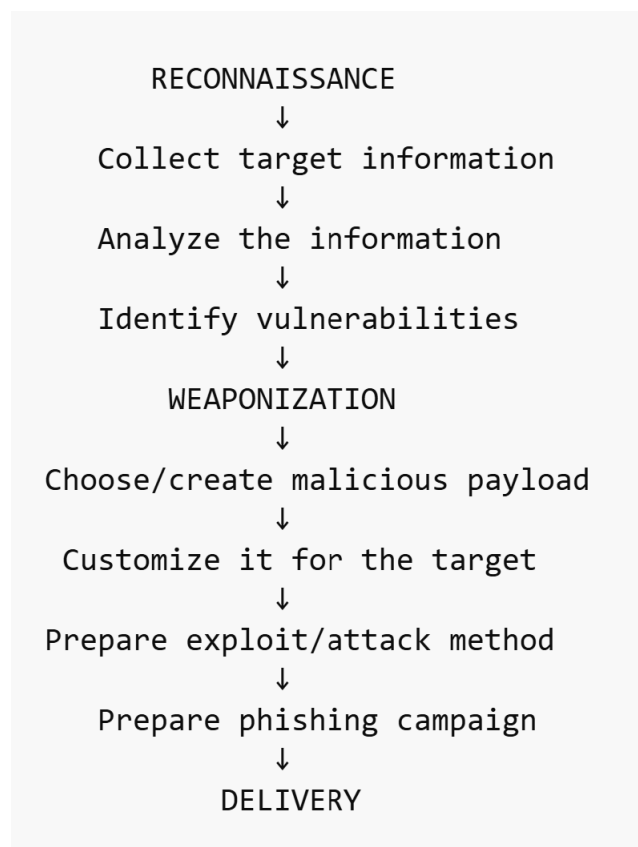


Figure 1.4: Cyber kill chain methodology

Step 1 : Reconnaissance



Step 2 : Weaponization



Step 3 : Delivery

Delivery-stage activities

- **Phishing emails:** Sending employees emails containing malicious attachments or links intended to deliver the payload.
- **Malicious USB drives:** Distributing infected USB devices and relying on employees to connect them to organizational systems.
- **Watering-hole attacks:** Compromising websites that target employees are likely to visit so that malicious content can be delivered to their devices.
- **Exploitation of exposed systems:** Using hacking tools or vulnerabilities in operating systems, applications, and servers to deliver or introduce the payload.

Main objective

The **effectiveness of an organization's defensive controls** at this stage is measured by whether these delivery attempts are detected, blocked, or prevented before the payload reaches the intended systems or users.

Step 4 : Exploitation

- **Exploitation:** A vulnerability or user action causes the malicious payload to execute.
- **For example**, a malicious document may exploit a vulnerability in an application when the victim opens it.
-
- Exploitation triggers the adversary's malicious code to **exploit a vulnerability** in the operating system, application, or server on a target system. At this stage, the organization may face threats such as **authentication** and **authorization** attacks, **arbitrary code execution (this means an attacker is able to make the target system execute code chosen by the attacker.)**, physical security threats, and security misconfiguration.

Step 5 : Installation:

- Downloading and installing malicious software such as **backdoors**.
- Gaining **remote access** to the target system.
- **Leveraging** various methods to **keep backdoor hidden** and running.
- Maintaining access to the target system

Step 6 : Command and Control

- Establishing a **two-way communication** channel between the **victim's system** and the **adversary-controlled server**.

- **Leveraging** channels such as **web traffic**, **email communication**, and **DNS messages**.
- Applying privilege escalation techniques.
- **Hiding any evidence** of compromise using techniques such as **encryption**.

Step 7 : Actions on Objective

- This is the stage where the adversary finally does what they wanted to do after successfully getting into the target's systems.
-

Diamond Model of Intrusion Analysis

The 4 main parts

1. Adversary

The person or group carrying out the attack.

Example: A cybercriminal group.

2. Capability

The tools or techniques the attacker uses.

Example: Malware, phishing, password-stealing tools.

3. Infrastructure

The systems the attacker uses to conduct the attack.

Example: Malicious websites, command-and-control servers, compromised computers.

4. Victim

The person, organization, computer, or network being attacked.

Example: A bank's employee or company network.

Easy example

Imagine a hacker sends a phishing email:

Adversary: Hacker

Capability: Phishing technique

Infrastructure: Malicious website used to steal the password

Victim: Employee who clicks the link

So, the Diamond Model helps investigators ask:

Who attacked? → What did they use? → What infrastructure did they use? → Who was attacked?

Objective 05

Summarize the Techniques used in Information Security Controls.

This section deals with :

- 5.1 Information Assurance (IA)**
 - 5.2 Continual/adaptive security strategy.**
 - 5.3 Defense-in-depth.**
 - 5.4 Risk management.**
 - 5.5 Cyber threat intelligence.**
 - 5.6 Threat modeling.**
 - 5.7 Incident management.**
 - 5.8 AI and ML concepts.**
-

5.1 Information Assurance (IA)

IA assures the CIA triads of information and information systems during usage , processing , storage and transmission of data.